



File No.: EXP202305979

INDEX OF CONTENTS

RESOLUTION OF SANCTIONING PROCEDURE

.....

3

BACKGROUND

.....

3

FIRST

.....

3

SECOND:

.....

3

First notification of the personal data security breach

.....

3

Second notification of the personal data security breach

.....

5

Third notification of the personal data security breach

.....

6

Fourth notification of the personal data security breach

.....

7

Fifth notification of the personal data security breach

.....

8

RESULT OF THE INVESTIGATION PROCEEDINGS

.....

9

THIRD

.....

23

FOURTH

.....

23

FIFTH

.....

24

SIXTH

.....

24

PRELIMINARY ALLEGATION

.....
24
FIRST ALLEGATION. Preliminary clarifications regarding the security incidents suffered by CCC

.....
24
SECOND ALLEGATION. CCC has not violated the principle of integrity and confidentiality

.....
26
THIRD ALLEGATION: CCC adopted appropriate security measures

.....
30
FOURTH ALLEGATION. CCC acknowledges its responsibility regarding the alleged infringement of Article 34 of the GDPR: communication of breaches to affected individuals

.....
33
FIFTH ALLEGATION. List of documentary evidence

.....
33
SEVENTH: .

.....
34
EIGHTH

.....
34
NINTH

.....
34
TENTH

.....
35
ELEVENTH

.....
35
TWELFTH

.....
38
THIRTEENTH.....38
PROVEN FACTS

.....
38
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
2/62
FIRST
.....

38

First violation of personal data security

38

Second violation of personal data security

40

Third violation of personal data security

42

Fourth violation of personal data security

43

Fifth violation of personal data security

45

SECOND

46

THIRD

47

FOURTH:

47

FIFTH

49

SIXTH

51

SEVENTH

52

EIGHTH

52

NINTH.

52

TENTH

52

ELEVENTH

54

LEGAL GROUNDS

.....
54

I Jurisdiction

.....
55

II Preliminary Issues

.....
55

III

Response to the allegations regarding the initiation agreement

.....
57

FIRST ALLEGATION

.....
57

SECOND ALLEGATION

.....
58

THIRD ALLEGATION

.....
64

FOURTH ALLEGATION

.....
73

IV

Breach of obligation. Principle of integrity and confidentiality.

.....
74

V Classification and qualification of the infringement

.....
78

VI

Sanction

.....
79

VII

Breach of obligation. Security of processing.

.....
82

VIII

Classification and qualification of the infringement

.....
87

IX

Sanction

88

X Breach of obligation. Communication of a personal data security breach to the affected party.

90

XI Classification and qualification of the infringement

92

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

3/62

XII Sanction

93

XIII Adoption of measures

95

RESOLUTION

96

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure conducted by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On April 18 and 21, 2023, a personal data security breach was reported to the Division of Technological Innovation of this Agency, submitted by CENTROS COMERCIALES CARREFOUR, S.A. (hereinafter, Carrefour or CCC) with NIF A28425270, as the data controller, with entry registration numbers REGAGE23e00025023252 and REGAGE23e00025776926, respectively, concerning unauthorized access to personal data of the customer profile.

As a consequence of the known facts, on May 3, 2023, the Director of the Spanish Agency for Data Protection ordered the General Subdirectorate of Data Inspection (SGID) to carry out the necessary preliminary investigations in order to determine a possible violation of data protection regulations.

SECOND: The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the supervisory authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), being aware of the following details:

First notification of the personal data security breach: on January 13, 2023, and entry registration REGAGE23e00002601392, a notification of a personal data security breach was received in this Agency from the data controller Carrefour, with the following associated information:

(...)

Second notification of the personal data security breach: on January 20, 2023, and entry registration REGAGE23e00004163707, a notification of a personal data security breach was received in this

Agency from the data controller Carrefour, with the following relevant information:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/62

Third notification of the personal data security breach: on January 24, 2023, and entry record REGAGE23e00004641543, a modification of the previous breach is received, providing a technical report of the incident. This document is dated January 20, 2023, and from its analysis, the following relevant information is extracted:

(...)

Fourth notification of the personal data security breach: on April 18, 2023, and entry record REGAGE23e00025023252, a new breach notification is received from the responsible party, Carrefour, with the following relevant associated information:

(...)

Fifth notification of the personal data security breach: on April 21, 2023, and entry record REGAGE23e00025776926, a new entry is received through which the information regarding the last breach notified on April 18, 2023, is expanded, specifically:

(...)

RESULT OF THE INVESTIGATION ACTIONS

On June 23, 2023, a request for information directed to the responsible party, Carrefour, is notified, marked by the following lines of investigation:

- Investigate the processing activity affected by the breach.
- Investigate the procedures implemented to manage security breaches.
- Investigate the risk analyses and possible impact assessments conducted.
- Investigate the preventive and reactive measures implemented.
- Investigate the communications to the affected parties, means used, and dates on which they were made.

On a date subsequent to the notification of the previous request, a new security breach notification is received in this Agency from CARREFOUR, dated June 26, 2023, and entry record REGAGE23e00041661209. From its analysis, the relevant information is extracted:

(...)

On July 7, 2023, and entry record REGAGE23e00045766091, a response is received from CARREFOUR to the request for information notified on June 23, 2023. From the analysis of the documentation provided, the following relevant information for the investigation is extracted:

- The Record of Processing Activities (RAT) is provided with very detailed information about the activity affected by the breach, specifically:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/62

o Activity: "Club Carrefour Customers".

o Purpose: "Management of the loyalty club, Customer service, Management of advertising, Fraud prevention, Profiling, Customer behavior analysis, Evaluation of potential customers, Market research, Direct marketing, Contractual purposes".

o Affected data: Postal Code, consumption frequency, date of birth, data of first-degree relatives, billing address, date of birth of children, name, geolocation information, home address, commercial communication interests and preferences, surnames, marital status, ID number, nationality, foreign identification number (NIE), passport number, personal email address, phone numbers, purchasing trends, gender.

o Minimization and governance measures:

☐ (...)

o Technical measures:

☐ (...)

o Minimization measures regarding concept and design:

☐ (...).

- A document is provided with the existing internal procedure for managing security breaches; from the analysis of this document, the following relevant information is extracted:

(...)

THIRD: According to the report collected from the AXESOR tool, the entity CENTROS COMERCIALES CARREFOUR, S.A., is a large company established in 1976, with a turnover of €9,027,949,000 in 2022.

FOURTH: On April 29, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the investigated entity, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of the GDPR, for the alleged infringement of Article 32 of the GDPR, classified in Article 83.4 of the GDPR, and for the alleged infringement of Article 34 of the GDPR, classified in Article 83.4 of the GDPR.

The initiation agreement was sent in accordance with the rules established in the LPACAP, via electronic notification, being received on April 30, 2024, as stated in the certificate in the file.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/62

FIFTH: Having requested an extension of the deadline granted to submit allegations, pursuant to the provisions of Article 32.1 of the LPACAP, on May 6, 2024, it was agreed to extend said deadline by a maximum of five days, which should be counted from the day following the end of the initial deadline for allegations.

SIXTH: Once the aforementioned initiation agreement was notified in accordance with the rules established in the LPACAP, the investigated entity submitted a written statement of allegations in which, in summary, it states:

PRELIMINARY ALLEGATION

- that it has not infringed Articles 5.1 f) and 32 of the GDPR. It dedicates Allegations Two and Three to this issue.

- it acknowledges responsibility for the alleged infringement of Article 34 of the GDPR, relating to the communication of breaches to the affected individuals. It dedicates Allegation Four to this issue.

- and dedicates Allegation Five to listing the documents provided by CCC along with this written statement of allegations.

Before presenting the reasons why it believes that there has been no infringement of Articles 5.1 f) and 32 of the GDPR, it makes a series of clarifications regarding the nature and dynamics of the attacks that led to the incidents suffered by CCC.

FIRST ALLEGATION. Preliminary clarifications regarding the security incidents suffered by CCC

Firstly, regarding the obtaining of credentials, it states that the incidents originated from the acquisition of credentials (username and password) by a third party. The acquisition of these credentials occurred in an environment external to CCC. That is to say, access to this first personal data (credentials) did not occur in databases for which CCC is responsible. In this regard, it points out that the hash function used to protect the credentials is currently considered robust. It provides Document 1 as an explanatory document.

Secondly, regarding access requests, it indicates that the number of affected accounts reported to the Agency in each of the communicated security breaches corresponds to the number of accounts for which the third party confirmed the validity of the credentials; these are not accounts to which the third

party had access, nor did it have access to the personal data of those customers.

Thirdly, once the third party has confirmed the validity of the credentials, it proceeds to sell them through various channels. It provides Document 2, which includes two screenshots from ***APP.1 showing how credentials from various merchants, including CCC, are offered. In this way, the third party will obtain financial compensation from the sale of these verified credentials, and the third party that purchases the credentials will be able to use them to access the customer area and attempt to commit economic fraud through the use of the chequeAhorro.

However, it notes that access will not occur if: there is no buyer or the buyer does not use the credentials; if the compromised credentials have been reset; and/or a two-factor authentication has been implemented.

Additionally, it makes some further clarifications:

It understands that there has been no unauthorized or unlawful access to 118,895 customer accounts and, therefore, no impact on the integrity and/or confidentiality of the personal data of the holders of those accounts in all these cases.

It considers that there are only 234 cases in which the integrity of the personal data of customers has been affected; and 973 cases in which the confidentiality of the Affected Personal Data has been compromised.

The First, Second, Third, and Fourth Breaches affected the CCC application, while the Fifth Breach affected the website.

(...)

In relation to the penetration tests (also known as pentests) conducted after the First Breach, it wishes to clarify that these are not measures adopted reactively and that CCC conducts pentests periodically for both the website and the application prior to the incidents. In this regard, it clarifies that certain security measures (gray box) were deactivated for the audits, which is why the recommendations and improvements identified in those audits do not correspond to reality and should be qualified.

Based on the clarifications made in this First Allegation, it then proceeds to assess the existence of an infringement of Articles 5.1 f) (Second Allegation) and 32 of the GDPR (Third Allegation).

SECOND ALLEGATION. CCC has not infringed the principle of integrity and confidentiality.

It reiterates that the compromise of the confidentiality of the personal data of CCC customers has occurred in only 973 cases.

Regarding integrity, the cases in which it was affected amount to 234. In this sense, it should be noted that:

a) As communicated in the First Breach, it has been verified that there were only 234 cases of customers whose personal data were modified. The data that were modified included the email address, delivery address, as well as, in some cases, the phone number and name.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/62

b) In fact, on March 14, two-factor authentication was implemented for modifying personal data from the client area, so the integrity of personal data was not compromised in the rest of the breaches.

Regarding confidentiality, the cases in which it was affected amount to 973. This number corresponds to the cases in which fraud was detected in clients' chequeAhorro, which are distributed among: (i) the 234 cases from the First Breach, where the impact on integrity also involved an impact on confidentiality; and (ii) 739 cases distributed between the Second and Fifth Breaches.

The resetting of credentials prevents the buyer from accessing the client area of the affected person.

(...)

Therefore, the total number of affected individuals reported in the breaches (118,895) does not correspond to the total cases in which integrity and confidentiality were affected, but rather the impact on integrity was limited to 234 clients and the impact on confidentiality to 973.

It indicates that CCC did adopt appropriate technical and organizational measures to prevent the loss of integrity and confidentiality from occurring again and, in any case, to effectively reduce the likelihood

of the materialization of the loss of integrity and confidentiality of its clients' personal data.

Below is a list of the measures adopted prior to the first breach of personal data security.

Technical measures:

(...)

Organizational measures:

(...)

It provides as Document 4 a copy of the extension and renewal agreement of the cybersecurity and vulnerabilities contract signed with ***COMPANY.1, which certifies that these services were in effect prior to the First Breach.

(...)

It also provides as Document 9 a report issued by ***COMPANY.2 concluding that CCC's compliance status is superior to that of other benchmark entities in the retail sector.

For all the above reasons, it understands that the technical and organizational measures adopted by CCC were indeed adequate to prevent the loss of integrity and confidentiality from occurring again or, at a minimum, to effectively reduce the likelihood of the materialization of the loss of integrity and confidentiality of its clients' personal data.

Subsidiarily, in the event that the Agency finds that there has been an infringement and a sanction must be imposed on CCC, the following mitigating circumstances should be taken into account:

- o The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered (Article 83.2 a) of the GDPR):

It understands that the amount of the sanction should be reduced considering that the number of affected individuals whose integrity and/or confidentiality of their personal data has been compromised is 973, not 118,895. Furthermore, it considers that, although a set of data (name and surname, complete postal address, and date of birth) has been affected in these cases, they are not critical, especially considering that, as stated (Document 2), the ultimate goal pursued by the third party is to commit economic fraud, with the affected personal data being a means to commit such fraud, not an end in itself.

- o The intentionality or negligence in the infringement (Article 83.2 b) of the GDPR:

(...)

Furthermore, CCC understands that the following circumstances should be taken into account as mitigating factors:

- i. Any other measures taken by the data controller to mitigate the damage and harm suffered by the affected parties (Article 83.2 c) of the GDPR).

It considers that the fact that CCC took measures to mitigate the damage and harm suffered by the affected individuals should be taken into account as a mitigating factor. In this regard: it reset the credentials that had been affected; and in those cases where fraud occurred in the chequeAhorro, CCC reimbursed the amount of the chequeAhorro and issued gift cards for the affected individuals, so that they did not suffer any economic impact resulting from the fraud.

Moreover, these measures were taken spontaneously, before CCC became aware of the information requests and the initiation of the Agency's investigation.

- ii. The degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement (Article 83.2 f) of the GDPR), as well as how the supervisory authority became aware of the infringement, particularly whether the controller notified the infringement and, if so, to what extent (Article 83.2 h of the GDPR).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/62

CCC considers that this mitigating factor is applicable insofar as the Initiation Agreement has been issued as a consequence of the five security breaches communicated by CCC to the Agency. It should be valued as a mitigating factor that notification was made, diligently fulfilling this duty. Information was

provided with complete transparency, and for this reason, it also understands that these mitigating circumstances should apply. Finally, CCC has cooperated favorably with the investigation, responding to all requests made.

ALLEGATION THREE: CCC adopted appropriate security measures.

It states that CCC adopted appropriate security measures, without prejudice to the fact that, if Articles 5.1 f) and 32 of the GDPR were deemed infringed (which is not the case), we would be facing a single infringement and that the alleged lack of appropriate technical and organizational measures should be understood as encompassed, as a means of perpetration, in the infringement of the principles of integrity and confidentiality.

(...)

Regarding the pentests of ***COMPANY.1, it indicates that CCC did not conduct the pentest reactively after the first breach. The pentests are part of a wide range of technical and organizational measures adopted by CCC to preserve the confidentiality, integrity, and availability of the personal data processed.

The pentests were – and continue to be – conducted periodically for both the website and the application. In this regard, it refers to the service provision contract SOC signed with ***COMPANY.1 (Document 4), which includes a web application security audit service. Additionally, it provides as Document 10 a certificate prepared by ***COMPANY.1 certifying the pentests conducted prior to the First Breach.

In this sense, it states that it is true that the report refers to alleged "deficiencies in the controls implemented in CCC's information systems." However, it indicates that it must be taken into account that certain security measures (grey box) were deactivated for the audits, so the recommendations and improvements detected in those audits do not correspond to reality and must be qualified. It attaches tables listing the short-term recommendations identified in the pentests and includes a justification for their lack of relevance.

For all the above reasons, it understands that the technical and organizational measures adopted by CCC were indeed appropriate according to what is stated in Article 32 of the GDPR. Subsidiarily, in the event that the Agency understands that an infringement has occurred and a sanction must be imposed on CCC, it considers that the following aggravating and mitigating circumstances should be taken into account:

- o The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered (Article 83.2 a) of the GDPR)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/62

It is understood that the fact that there has been an impact on the Affected Personal Data is considered an aggravating factor (in which case it must be limited to the clients who were actually affected, not to all users of the website and the application), or, conversely, it is considered an aggravating factor that the impact due to the lack of technical and organizational measures affects all users of the website and the application (in which case it cannot be argued that there has been an effective impact on their personal data, since it has only occurred in certain cases).

In any case, it is considered that, despite the fact that in certain cases a set of data (name and surname, complete postal address, and date of birth) has been affected, these are not critical, especially considering that the ultimate goal pursued by the third party is to commit economic fraud, with the affected personal data being a means to commit such fraud, not an end in itself.

Regarding the duration, it has been observed how the progressive application of new measures has reduced the impact (implementation of the second factor to modify personal data and to access the application, among others), therefore it is understood that this circumstance cannot be taken into account as an aggravating factor.

o

Intentionality or negligence in the infringement (Article 83.2 b) of the GDPR)

To the extent that the Agency's argument is the same as that used when addressing this circumstance for the alleged infringement of Article 5.1 f) of the GDPR, reference is made to what has been stated in relation to it in Allegation Two.

Additionally, CCC understands that the following circumstances should be taken into account as mitigating factors:

i. Any other measures taken by the data controller to mitigate the damages suffered by the data subjects (Article 83.2 c) of the GDPR)

CCC adopted technical and organizational measures aimed at reducing the likelihood of the risk materializing. Furthermore, these measures were adopted proactively, that is, prior to becoming aware of the Agency's investigations that have resulted in the issuance of the Initiation Agreement.

ii. The degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement (Article 83.2 f) of the GDPR), as well as the manner in which the supervisory authority became aware of the infringement, particularly whether the controller reported the infringement and, if so, to what extent (Article 83.2 h of the GDPR).

Reference is made to what has been stated for this circumstance in Allegation Two.

ALLEGATION FOUR. CCC acknowledges its responsibility regarding the alleged infringement of Article 34 of the GDPR: communication of breaches to the affected individuals.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/62

Although CCC considered at the time that it was not mandatory to communicate the breaches to the affected individuals, CCC acknowledges its responsibility solely and exclusively for the alleged infringement of Article 34 of the GDPR, in relation to those individuals whose confidentiality and/or integrity of their personal data was affected, which should lead to a reduction of 20% of the proposed sanction for this infringement (200,000 euros). Furthermore, if payment is made before the resolution of this procedure, the sanction should be reduced by an additional 20%, making the amount to be paid 120,000 euros.

FIFTH ALLEGATION. List of documentary evidence submitted, for the purpose of demonstrating the absence of infringement or, where applicable, reducing the proposed sanction by the Agency.

a) As Document 1, explanatory document of the hash function used by ***COMPANY.3.

b) As Document 2, screenshots of channels of ***APP.1 where credentials of CCC customers were offered.

c) As Document 3, screenshots of channels of ***APP.1 where the impossibility of using the acquired credentials was mentioned.

d) As Document 4, copy of the extension and renewal agreement of the cybersecurity and vulnerabilities contract signed with ***COMPANY.1.

e) As Document 5, copy of the audit report from ***COMPANY.4 (2022).

f) As Document 6, copy of the compliance matrix of CCC (...).

g) As Document 7, information on the implementation of the second factor of authentication in the digital channels of other leading retailers in Spain.

h) As Document 8, document in the call log to (...) of ***COMPANY.3.

i) As Document 9, copy of the report issued by ***COMPANY.2 in May 2024.

j) As Document 10, copy of a certificate from ***COMPANY.1 listing the pentests conducted prior to the First Breach.

By virtue of all the above, it requests in relation to the alleged infringement of Article 34 of the GDPR, to recognize the responsibility of Centros Comerciales Carrefour, S.A. and in relation to the alleged infringements of Articles 5.1 f) and 32 of the GDPR: the dismissal of the proceedings with the consequent filing of the actions, for not having committed any of the alleged infringements.

Alternatively, that, in the event that any sanction is imposed, it be imposed at a minimum amount, in light of the mitigating circumstances indicated.

Finally, it states that it does not yet have the translation into Spanish of Documents 5 and 6, and announces that it will provide these translations as soon as they are available and that it is preparing an additional document regarding the process followed in the digital channels identified in the table provided as Document 7, related to the implementation of the second factor of authentication in the digital channels of other leading retailers in Spain, and that it will submit this additional document as soon as it is available.

SEVENTH: On June 17, 2024, as part of the documentation that it announced it would provide has not been received, it is requested to submit it within a period of 5 days, with an indication that, in case this documentation is not submitted,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
13/62

The procedure will continue in accordance with the provisions of Article 77 of the LPACAP.

In compliance with the request, on June 25, 2024, Document 7 bis is submitted, which contains a sampling of the process followed in some of the digital channels identified in the table provided as Document 7, as well as the translations into Spanish of Documents 5 and 6, as Document 5bis and Document 6bis.

EIGHTH: On October 16, 2024, the instructor of the procedure agreed to open a period for the practice of evidence for a duration of 20 (twenty) days, starting from the day following the notification of the act, in accordance with the provisions of Articles 77 and 78 of the LPACAP, considering the documentation provided by Carrefour to be reproduced for evidentiary purposes, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection, the report of preliminary investigative actions that are part of procedure AI/00154/2023, the allegations to the initiation agreement of the sanctioning procedure presented by Carrefour, and the documentation accompanying them.

It was also agreed to require Carrefour to provide, within a period of 10 working days, counted from the acceptance of the notification of said writing, the following information and/or documentation:

- Password policy that includes the measures implemented and the date of their implementation.
- Number of accounts, out of the 1,741 already compromised in the third personal data breach, to which the third party had access in the fourth personal data breach.
- Reports of penetration tests (Pentest) conducted by Carrefour in 2022, on the Ecommerce website carrefour.es and on the Carrefour APP.
- Date of implementation of the measures recommended in the reports of the penetration tests (Pentest) conducted on the website and on the Carrefour APP, completed on 03/03/2023 and 09/02/2023, respectively.
- Total number of access requests made by the attacker against the Carrefour website and APP for each of the five personal data breaches, including requests to Carrefour accounts that did not result in "OK".

NINTH: On October 24, 2024, in response to the writing requesting an extension of the deadline granted to him, pursuant to Article 32.1 of the LPACAP, it was agreed to extend the deadline by a maximum of five days, which should be counted from the day following the end of the first deadline.

TENTH: On October 31, 2024, in response to the submitted writing, a copy of the requested file was sent in accordance with the provisions of Article 53.1 a) of the LPACAP.

ELEVENTH: On November 8, 2024, CCC submitted a response to the information request, in which it states the following:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

14/62

1. Password policy that includes the measures implemented and the date of their implementation. The current password policy of CCC was implemented in June 2022. According to this policy, for a password to be valid, it must meet the following characteristics:

(...)

It provides as Document 1 the development sheet of the password policy modified in June 2022 and a screenshot with the characteristics that passwords must meet to be valid.

2. Number of accounts, out of the 1,741 already compromised in the third personal data breach, to which the third party had access in the fourth personal data breach.

In the Third Breach (notified on April 21, 2023), there were 61,083 successful access requests (result "OK") and in the Fourth Breach (notified on June 26, 2023), there were 10,943. The number of matching accounts in the two breaches – that is, for which the third party's query resulted in an "OK" – was 1,741.

3. Reports of penetration tests (Pentest) conducted by Carrefour in 2022, on the Ecommerce website Carrefour.es and on the Carrefour APP.

It provides as Document 2 the Report.

It states that the vulnerabilities identified in the pentest (none of critical or high severity) were detected as a result of providing information to the auditor about the infrastructure of CCC's systems and the deactivation of security measures to allow the audit to be conducted.

4. Date of implementation of the measures recommended in the reports of the penetration tests (Pentest) conducted on the website and on the Carrefour APP, completed on 03/03/2023 and 09/02/2023, respectively.

Regarding the pentest for the application (February 28, 2023):

A total of 10 recommendations were included, listed in the following sections of the pentest: 5.1.4, 6.1.4, 6.2.4, 6.3.4, 6.4.4, 7.1.4, 7.2.4, 7.3.4, 7.4.4, and 7.5.4.

Of these 10 recommendations:

a) One of them (5.1.4, corresponding to a high severity vulnerability) was implemented on February 13, 2023, as stated in the pentest itself:

5.1 Insecure Reference to Objects (IDOR) (CORRECTED)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/62

b) Four of them (6.1.4, 6.2.4, 7.1.4, and 7.2.4, all corresponding to medium severity vulnerabilities) are not applicable, as they are recommendations derived from vulnerabilities that were detected as a result of providing information to the auditor about the infrastructure of CCC's systems and the removal of security measures to facilitate the auditor's work during the pentest in gray box mode.

c) The remaining five (6.3.4, 6.4.4, 7.3.4, 7.4.4, and 7.5.4, all corresponding to low severity vulnerabilities) were accepted, meaning they were not implemented as the attack vector for these vulnerabilities was local or physical, resulting in a low and very reduced risk, particularly in the case of physical attack vectors, where the attacker needs to physically interact with the client's device.

d) In any case, none of the 10 recommendations have an impact on the breaches covered by the initiation agreement of the sanctioning procedure.

Regarding the pentest for the website (March 6, 2023):

A total of 19 recommendations were included, listed in the following sections of the pentest: 5.1.4, 5.2.4, 5.3.4, 5.4.4, 5.5.4, 5.6.4, 5.7.4, 5.8.4, 5.9.4, 5.10.4, 5.11.4, 5.12.4, 5.13.4, 5.14.4, 5.15.4, 5.16.4, 5.17.4, 5.18.4, and 5.19.4.

Of these 19 recommendations:

a) Four of them were implemented on the following dates:

- 5.1.4 (corresponding to a critical severity vulnerability) was implemented on July 11, 2023. We provide supporting documentation for the implementation of the recommendation as Document 3.

- 5.6.4 (corresponding to a medium severity vulnerability) was implemented in September 2024.
- 5.9.4 (corresponding to a medium severity vulnerability) was implemented in September 2024.
- 5.17.4 (corresponding to a low severity vulnerability) was implemented in September 2024.

Document 4 provides the documentary justification for the implementation of recommendations 5.6.4, 5.9.4, and 5.17.4. As can be seen in the "Configuration" section, CCC does not use RC4 cipher suites (recommendation 5.6.4), triple-DES, and 64-bit block ciphers (recommendation 5.9.4) and CBC type ciphers (recommendation 5.17.4).

b) One of them (5.2.4, corresponding to a high severity vulnerability) could not be reproduced by the auditor and was ultimately marked as corrected, as shown in the screenshot provided as Document 5. C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/62

c) Three of them (5.5.4, 5.7.4, and 5.8.4; all corresponding to medium severity vulnerabilities) are not applicable, as they are recommendations derived from vulnerabilities that were detected as a result of providing information to the auditor about the infrastructure of CCC's systems and the removal of security measures to facilitate the auditor's work during the pentest in gray box mode.

d) Two of them (5.3.4 and 5.4.4; both corresponding to medium severity vulnerabilities) were not implemented, as the corresponding vulnerabilities cannot be exploited due to the existence of other security measures (in both cases, the use of web application firewalls) applied by CCC. In fact, in 5.3, the auditor admits that it has not been possible to "verify the exploitation of this vulnerability" and that its existence is to be reported for the purpose of "requesting its mitigation if necessary."

e) The remaining nine (5.10.4, 5.11.4, 5.12.4, 5.13.4, 5.14.4, 5.15.4, 5.16.4, 5.18.4, and 5.19.4; the first three corresponding to medium severity vulnerabilities and the remaining six to low severity vulnerabilities) were accepted, meaning they were not implemented as the vulnerabilities – and the consequent recommendations – did not exceed the threshold of materiality.

f) In any case, none of the 19 recommendations have an impact on the breaches covered by the initiation agreement of the sanctioning procedure.

5. Total number of access requests made by the attacker against the Carrefour website and APP for each of the five personal data breaches, including requests to Carrefour accounts that did not result in "OK."

CCC does not retain the number of unsatisfactory requests for the five breaches.

However, the numbers of satisfactory requests for each breach are as follows:

Breach

Satisfactory access requests

First Breach

(...)

Second Breach

(...)

Third Breach

(...)

Fourth Breach

(...)

Fifth Breach

(...)

TWELFTH: On December 5, 2024, a resolution proposal was made, proposing:

<<. That the Director of the Spanish Agency for Data Protection sanctions CENTROS COMERCIALES CARREFOUR, S.A., with NIF A28425270,

- for the infringement of Article 5.1.f) of the GDPR, classified according to the provisions of Article 83.5 of the GDPR, as very serious for the purposes of prescription, in Article 72.1 a) of the LOPDGDD, with a fine of 2,000,000 euros.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
17/62

- for the infringement of Article 32 of the GDPR, classified in accordance with the provisions of Article 83.4 of the GDPR, deemed serious for the purposes of limitation, in Article 73 f) of the LOPDGDD, with a fine of 1,000,000 euros.

- for the infringement of Article 34 of the GDPR, classified in accordance with the provisions of Article 83.4 of the GDPR, deemed minor for the purposes of limitation, in Article 74 ñ) of the LOPDGDD, with a fine of 200,000 euros.

That the Director of the Spanish Agency for Data Protection orders CENTROS COMERCIALES CARREFOUR, S.A., with NIF A28425270, to comply with the following measure, pursuant to Article 58.2.d) of the GDPR, within one month, to prove that it has proceeded to comply with the communication of personal data breaches to the affected individuals whose data has been affected in the terms and conditions provided by Article 34 of the GDPR.

The aforementioned proposal for resolution was sent, in accordance with the rules established in the LPACAP, by electronic notification, being received on December 10, 2024, as stated in the certificate in the file.

THIRTEENTH: The investigated entity has not submitted allegations to the Proposal for Resolution. In view of all the actions taken by the Spanish Agency for Data Protection in this procedure, the following facts are considered proven,

PROVEN FACTS

FIRST: Notifications of personal data breaches:

Carrefour has reported up to five security breaches of personal data, all related to unauthorized third-party access to customer accounts, likely using the attack technique of Credential Stuffing utilizing leaked credentials (email/password pairs), with no evidence showing brute force attacks.

First personal data security breach

The Preliminary Investigation Report contains the following information:

(...)

Second personal data security breach:

The Preliminary Investigation Report contains the following information:

(...)

Third personal data security breach

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/62

The Preliminary Investigation Report contains the following information:

(...)

Fourth personal data security breach:

(...)

Fifth personal data security breach:

The Preliminary Investigation Report contains the following information:

(...)

SECOND: (...), on July 7, 2023, the investigated entity included in response to the request made by the inspector, a list of personal data that could have been accessed, organized by data type:

o Name, Surname 1, Surname 2

o Email Address

o Contact Phone (masked with asterisks all digits except the last 3)

o ID Number (masked with asterisks all characters except the last 4)

o Complete postal address: Postal code, Staircase/floor/door, Municipality, Street name, Street number, Province, Type of street, Date of birth.

Furthermore, it is noted in the notification of the third personal data breach, which occurred on April 18, 2023, that the attacker had access to Basic Data (e.g., name, surnames, date of birth), ID Number, NIE, Passport and/or any other identifying document, Economic or Financial Data (without payment methods), Contact Data, Access or Identification Credentials (username and/or password).

In the notification of the fourth personal data breach, which occurred on June 23, 2023, it is stated that the attacker accessed Basic Data (e.g., name, surnames, date of birth), Contact Data, Access or Identification Credentials (username and/or password).

In the notification of the fifth personal data breach, which occurred on September 11, 2023, it is stated that the attacker had access to Basic Data (e.g., name, surnames, date of birth), ID Number, NIE, Passport and/or any other identifying document, Contact Data, Access or Identification Credentials (username and/or password).

THIRD: Regarding the possible insufficiency of existing security measures, (...).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/62

FOURTH: Carrefour has provided the Data Protection Impact Assessment (DPIA) for the processing activity affected by the breach ("Club Carrefour Customers") created on April 14, 2021, and ending on July 19, 2022.

It is noted that this document analyzes the various legal bases for the processing and uses the contract as the legitimate basis for the processing (referring to the acceptance of the Legal Bases of The Club and My Account as the signing of a contract for the processing of the personal data of the data subject).

On the other hand, they also use other legitimate bases for the following purposes:

- ****Legitimate interest:**** For prior verification against the CC CARREFOUR databases, management of advertising, achieving the centralization of customer processing operations, development of sales processes and channels, behavior analytics, and review of suspicious operations, fraud prevention.

- ****Express consent:**** (i) sending advertising by Carrefour regarding products from collaborating entities and Group and Non-Group Affiliated Entities (Iberdrola, Cepsa, etc.) (ii) transfer of personal data to Group Carrefour Affiliated Entities for their own advertising.

It is stated that this processing involves profiling, but without legal effects for the data subjects:

Notwithstanding that systematic evaluations of customers are carried out, they do not have legal effects on them; it only impacts the type of advertising that club members receive.

A description of the processing and the flow of data is provided, detailing each of the assets involved in the various phases of collection, storage, and destination of the processed personal data.

Risk analysis and management are conducted, highlighting:

- The risk factor of identity theft that poses a financial or privacy risk is analyzed, assigning it an inherent risk value of High Impact and a residual risk value of Medium Impact.

- The financial risk for the subjects involved in the processing is analyzed, initially assigning it a value of Very High inherent risk and a Low residual risk value.

- The risks of loss of confidentiality are analyzed, assigning an inherent risk value of High Impact and a Low residual risk.

- Among the security measures mentioned to manage the risks are:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/62

Additionally, an annex document to the DPIA is included, which incorporates a list of ongoing security projects being developed throughout 2023 to enhance security. From the analysis of this document, it is extracted:

(...)

The report concludes with the following recommendations and actions to be taken:

(...)

(ii) Report of the Pentest on the Carrefour APP for Android/iOS, conducted from February 6, 2023, to February 9, 2023.

From its analysis, it is extracted:

Regarding the methodology (point 3 of the report) (...).

- A high-level vulnerability is detected (although it is stated in the same report that it has been corrected), 5 medium-level vulnerabilities, and 5 low-level vulnerabilities.

- The report concludes with the following recommendations on actions to be taken:

(...)

SIXTH: In this case, it has been confirmed that Carrefour sent a communication, on June 23, 2023, to 9,202 affected individuals, corresponding to the fourth personal data breach, and on September 11, 2023, to 10,959 affected individuals, corresponding to the fifth personal data security breach.

From the investigative actions carried out by this authority, the entity under investigation states that it proceeded to communicate via email, as well as through the push channel in cases of customers available by this means, and the content of the message sent was as follows:

"Dear customer:

To provide you with better service, we have reset your password. To obtain a new one, please request it at 'Forgot your password?' when accessing the App or the website.

On the website

<https://www.carrefour.es/myaccount>

In the App

Log in and click on 'Forgot your password?'

Best regards,

The Carrefour team"

It is not recorded that Carrefour communicated to the affected individuals regarding the first, second, and third personal data breaches, in the terms indicated in Article 34 of the GDPR, although this possible infringement due to the lack of communication to the affected individuals regarding the first, second, and third personal data breaches should be considered time-barred.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/62

SEVENTH

: The current password policy of CCC was implemented in June 2022. According to this policy, for a password to be valid, it must meet the following characteristics:

- (...)

Document 1 includes the development sheet of the password policy modified in June 2022 and a screenshot with the characteristics that passwords must meet to be valid.

EIGHTH: In the Third Breach (notified on April 21, 2023), there were 61,083 successful access requests (result "OK") and in the Fourth Breach (notified on June 26, 2023), there were 10,943. The number of matching accounts in both breaches – that is, for which the third-party query resulted in an "OK" – was 1,741.

NINTH: Carrefour has provided the Report of the penetration test (Pentest) conducted in 2022, titled "****REPORT.1".

Regarding the severity of the occurrences, the report indicates:

High Medium Low

0

6

3

Additionally, the Executive Summary of the report includes the following recommendations:

- In the short term:

(...)

- In the medium term:

(...).

- In the long term:

(...)

TENTH

: Date of implementation of the recommended measures in the reports of the penetration tests (Pentest) conducted on the website and in the Carrefour APP, completed on 03/03/2023 and 09/02/2023, respectively.

Regarding the pentest for the application (February 28, 2023):

A total of 10 recommendations were included, listed in the following sections of the pentest: 5.1.4, 6.1.4, 6.2.4, 6.3.4, 6.4.4, 7.1.4, 7.2.4, 7.3.4, 7.4.4, and 7.5.4.

Of these 10 recommendations:

a) One of them (5.1.4, corresponding to a high severity vulnerability) was implemented on February 13, 2023, as evidenced in the pentest itself:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/62

5.1 Insecure Reference to Objects (IDOR) (CORRECTED)

b) Four of them (6.1.4, 6.2.4, 7.1.4, and 7.2.4, all corresponding to medium severity vulnerabilities) are not applicable, as they are recommendations derived from vulnerabilities that were detected as a result of providing information to the auditor about the infrastructure of CCC's systems and the removal of security measures to facilitate the auditor's work in the pentest in gray box mode.

c) The remaining five (6.3.4, 6.4.4, 7.3.4, 7.4.4, and 7.5.4, all corresponding to low severity vulnerabilities) were accepted, meaning they were not implemented as the attack vector in these vulnerabilities was local or physical, thus the risk is low and very limited, particularly in the case of physical attack vectors, where the attacker needs to physically interact with the client's device.

d) In any case, none of the 10 recommendations have an impact on the breaches addressed in the initiation agreement of the sanctioning procedure.

Regarding the pentest for the website (March 6, 2023):

A total of 19 recommendations were included, listed in the following sections of the pentest: 5.1.4, 5.2.4, 5.3.4, 5.4.4, 5.5.4, 5.6.4, 5.7.4, 5.8.4, 5.9.4, 5.10.4, 5.11.4, 5.12.4, 5.13.4, 5.14.4, 5.15.4, 5.16.4, 5.17.4, 5.18.4, and 5.19.4.

Of these 19 recommendations:

a) Four of them were implemented on the following dates:

- Recommendation 5.1.4 (corresponding to a critical severity vulnerability) was implemented on July 11, 2023. We provide supporting documentation for the implementation of the recommendation as Document 3.

- Recommendation 5.6.4 (corresponding to a medium severity vulnerability) was implemented in September 2024.

- Recommendation 5.9.4 (corresponding to a medium severity vulnerability) was implemented in September 2024.

- Recommendation 5.17.4 (corresponding to a low severity vulnerability) was implemented in

September 2024.

Document 4 provides the documentary justification for the implementation of recommendations 5.6.4, 5.9.4, and 5.17.4. As can be seen in the "Configuration" section, CCC does not use RC4 cipher suites (recommendation 5.6.4), triple-DES, and 64-bit block ciphers (recommendation 5.9.4) and CBC type ciphers (recommendation 5.17.4).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/62

b) One of them (5.2.4, corresponding to a high severity vulnerability) could not be reproduced by the auditor and was ultimately marked as corrected, as shown in the screenshot provided as Document 5.

c) Three of them (5.5.4, 5.7.4, and 5.8.4; all corresponding to medium severity vulnerabilities) are not applicable, as they are recommendations derived from vulnerabilities that were detected as a result of providing information to the auditor about the CCC systems infrastructure and the removal of security measures to facilitate the auditor's work in the pentest in gray box mode.

d) Two of them (5.3.4 and 5.4.4; both corresponding to medium severity vulnerabilities) were not implemented, as the corresponding vulnerabilities cannot be exploited due to the existence of other security measures (in both cases, the use of web application firewalls) applied by CCC. In fact, in 5.3, the auditor admits that it has not been possible to "verify the exploitation of this vulnerability" and that its existence is to notify for the purpose of "requesting its mitigation if necessary."

e) The remaining nine (5.10.4, 5.11.4, 5.12.4, 5.13.4, 5.14.4, 5.15.4, 5.16.4, 5.18.4, and 5.19.4; the first three corresponding to medium severity vulnerabilities and the remaining six to low severity vulnerabilities) were not accepted, that is, they were not implemented as the vulnerabilities – and the consequent recommendations – did not exceed the materiality threshold.

f) In any case, none of the 19 recommendations have an impact on the breaches covered by the initiation of the sanctioning procedure.

ELEVENTH: CCC does not retain the number of unsatisfactory requests for the five breaches.

However, the numbers of satisfactory requests for each breach are as follows:

Breach

Satisfactory access requests

First Breach

(...)

Second Breach

(...)

Third Breach

(...)

Fourth Breach

(...)

Fifth Breach

(...)

LEGAL GROUNDS

I

Competence

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/62

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Presidency of the Spanish Data Protection Agency is

competent to resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

The public limited company Centros Comerciales Carrefour is a company dedicated to the operation of both large retail spaces and establishments located within them and, specifically, is specialized in the marketing in non-specialized establishments, with a predominance of food and beverages, also providing e-commerce services, for which it processes personal data of its customers and employees, understanding personal data as: "any information relating to an identified or identifiable natural person."

It carries out this activity in its capacity as data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR: "data controller" or "controller": the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; if the law of the Union or of the Member States determines the purposes and means of the processing, the controller or the specific criteria for its appointment may be established by the law of the Union or of the Member States.

An identifiable natural person is considered to be one whose identity can be determined, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person.

Furthermore, "processing" must be understood as "any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or otherwise making available, alignment, combination, restriction, erasure, or destruction."

Article 4, paragraph 12 of the GDPR broadly defines "personal data breaches" as "all breaches of security that lead to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
25/62

personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data."

In this case, up to five breaches of personal data have been reported by the data controller CARREFOUR, all of which are related to unauthorized access to customer accounts by unauthorized third parties, making use, at least in four of them, with a high probability of the attack technique known as Credential Stuffing, using leaked credentials (email/password pairs), lacking evidence that shows a brute force attack.

During the course of the investigative actions carried out, it has been revealed that the second, third, fourth, and fifth personal data breaches, reported on January 20, 2023, April 18, 2023, June 26, 2023, and September 14, 2023, share the same type (Credential Stuffing), using automated methods that employed email addresses arranged in alphabetical order, indicating that the attacker was using some type of database as a dictionary to launch their attacks. The attacks were carried out in a short period of time and from multiple IP addresses, which, as CARREFOUR has stated, made it difficult to identify and stop them in real-time.

Regarding the possible source or origin of the credentials that the attackers may have used to carry out the Credential Stuffing attack, in its letter dated January 20, 2023, CARREFOUR reported that it was discovered on January 17, 2023, that credentials for some affected email addresses were being

offered in a ***APP.1 group. Furthermore, it reported in its letter dated July 7, 2023, that it was discovered that packages of exposed credentials from various organizations, including Carrefour Spain, are currently being offered on different Dark Web sites, although they claim that all attempts to locate the original source of this data by CARREFOUR have been unsuccessful due to the high complexity of locating such sites.

Regarding the type of personal data to which the attacker may have had access in the second breach of personal data security, Carrefour has reported that, once reactive measures were implemented following the first breach detected in January 2023, they are:

- o Name, Surname 1, Surname 2
- o Email Address
- o Contact Phone (masked with asterisks all digits except the last 3)
- o ID Number (masked with asterisks all characters except the last 4)
- o Complete postal address: Postal Code, Staircase/Floor/Door, Municipality, Street Name, Street Number, Province, Type of street, Date of birth.

Additionally, it is noted in the notification of the third breach of personal data, which occurred on April 16, 2023, that the attacker had access to Basic Data (e.g., name, surnames, date of birth), ID Number, Foreigner Identification Number, Passport, and/or any other

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/62

identification document, Economic or financial data (excluding payment methods), Contact data, Access or identification credentials (username and/or password).

In the notification of the fourth personal data breach, which occurred on June 23, 2023, it is stated that the attacker accessed basic data (e.g., first name, last name, date of birth), Contact data, Access or identification credentials (username and/or password).

In the notification of the fifth personal data breach, which occurred on September 11, 2023, it is stated that the attacker had access to basic data (e.g., first name, last name, date of birth), ID card, residence card, passport and/or any other identification document, Contact data, Access or identification credentials (username and/or password).

Within the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data is guaranteed in section 1.f) of Article 5 of the GDPR.

On the other hand, the security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which govern the security of processing, the notification of a personal data security breach to the supervisory authority, and the communication of a personal data security breach to the data subject, respectively.

Regarding the infringement of Article 33 of the GDPR, classified in Article 83.4 of the aforementioned Regulation, it is noted that the investigated entity suffered a personal data security breach of which it became aware on October 6, 2022, although it did not notify this Agency until January 13, 2023, without having substantiated the reasons justifying such delay. However, since the LOPDGDD establishes a statute of limitations of one year in its Article 74 m) for these infringements, its non-imputation is deemed appropriate.

III

Response to the allegations regarding the initiation agreement

In relation to the allegations made against the initiation agreement of the present sanctioning procedure, a response is provided to them according to the order presented by CCC:

FIRST ALLEGATION. Preliminary clarifications regarding the security incidents suffered by CCC

Carrefour states that the number of affected accounts reported to the Agency in each of the notifications of personal data security breaches corresponds to the number of accounts for which the third party obtained confirmation of the validity of the access credentials, but that these are not accounts to which the third party had access.

In this regard, it should be noted that, in the notification of the personal data security breach made by

Carrefour on 01/13/2023, it is stated that in the incident of 10/06/2022, the data of 234 customers were compromised; in the notification of 01/20/2023, it is stated that in the incident of 01/18/2023, the affected customers were 35,735; in the notification of 04/18/2023, 61,083 affected customers are noted in the incident of 04/16/2023; in the notification of 06/26/2023, a total of 10,943 affected customers is noted in the incident of 06/23/2023, and finally, in the notification of 09/13/2023, it is stated that the affected customers were 10,900 in the incident of 09/11/2023.

Breach

Requests for satisfactory access

First Breach

(...)

Second Breach

(...)

Third Breach

(...)

Fourth Breach

(...)

Fifth Breach

(...)

Therefore, despite Carrefour's argument, this AEPD considers that the personal data breaches reported by Carrefour affected a total of 118,895 unique accounts. In 118,895 accounts, the attacker obtained a successful authentication, thus confirming that the access credentials for those accounts were correct and achieved successful accesses to them. Therefore, they had access to personal information of the holders of those accounts, at least to the credentials they used to log in, which posed a high risk to the rights and freedoms of the data subjects.

It should be recalled at this point that the concept of personal data must be interpreted broadly, encompassing not only the personal data collected and stored by the data controller but also all information resulting from such processing (CJEU judgment of May 4, 2023, in case C-487/21), and that, therefore, the password/username data of users are personal data.

Thus, a total of 118,895 access credentials were compromised in the attacks. The acquisition of the credentials constitutes a serious risk for individuals whose security is compromised, as they may become victims of impersonation, scams, or fraud, among others.

In this way, since 10/06/2022, the third party confirmed the validity of the access credentials, which, as mentioned, posed a high risk to the rights and freedoms of individuals. Carrefour's credentials were sold in a ***APP.1 group; in this regard, Carrefour acknowledges that once the third party has confirmed the validity of the credentials, they proceed to sell them through various channels: dark web, deep web, ***APP.1 channels, etc.

Moreover, Carrefour claims to have sent a communication to those affected by the third breach and, on June 23, 2023, and September 11, 2023, to the affected parties corresponding to the fourth and fifth security breaches, respectively.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/62

While the communication did not clearly inform the affected individuals that Carrefour had suffered a breach of personal data security, they were not aware of the risks to which they had been exposed.

ALLEGATION SECOND. CCC has not infringed the principle of integrity and confidentiality.

Firstly, it states that the impact on the integrity and confidentiality of the personal data of CCC customers has occurred in only 973 cases.

It points out that the number of affected accounts reported to the Agency in each of the communicated security breaches corresponds to the number of accounts for which the third party obtained confirmation of the validity of the credentials; these are not accounts to which the third party had access, nor did they have access to the personal data of those customers.

Regarding integrity, it claims that the cases in which it was affected amount to 234 cases of customers whose personal data was modified. The data that was modified included the email address, delivery address, as well as, in some cases, the phone number and name.

Regarding confidentiality, it indicates that the cases in which it was affected amount to 973. This number corresponds to the cases in which fraud was detected in the customers' savings checks, which are distributed among: the 234 cases of the First Breach, where the impact on confidentiality also involved an impact on integrity, and 739 cases distributed between the Second and Fifth Breaches. It considers that the total number of affected individuals reported in the breaches (118,895) does not correspond to the totality of cases in which integrity and confidentiality were affected, but rather that the impact on integrity was limited to 234 customers and the impact on confidentiality to 973.

In this regard, it should be noted that the investigative actions carried out by this authority have allowed for the confirmation of:

(...)

In this regard, it cannot be argued in any way that there is no infringement of Article 5.1.f) of the GDPR, since, due to the failure to adopt adequate measures, there was unauthorized access to personal data by a third party, which resulted in the loss of confidentiality, integrity, and control of numerous personal data and affected all those whose data was disclosed, not only those customers whose data was subsequently impersonated. This constitutes a breach of the duty to guarantee the confidentiality and integrity of personal data, as indicated, Article 5.1.f) states that personal data must be processed in such a way as to ensure an adequate level of security, including protection against unauthorized or unlawful processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/62

Therefore, the risk of loss of confidentiality has materialized, which means that personal data may be used for unknown purposes (sold, communicated, published, etc.), all without the consent of their holders, resulting in a total and absolute loss of control over them. Furthermore, it also entails a very high risk of fraudulent use of the data (identity theft, fraud, financial losses, etc.) or that it may serve any other purpose that, under certain circumstances, constitutes a threat to its holders. It should also be noted that most of the affected personal data are data that cannot be modified or changed for others (name, surname).

This loss of control over one's own personal data translates into a violation of the fundamental right to data protection recognized in Article 18 of the Spanish Constitution, as indicated by the Constitutional Court (Judgment 292/2000, of November 30, 2000) "the fundamental right to data protection seeks to guarantee individuals a power of control over their personal data, over its use and destination, with the purpose of preventing its illicit trafficking and harm to the dignity and rights of the affected party (...)

The right to data protection guarantees individuals a power of disposition over that data."

In the case at hand, it has been established that CCC has violated this duty of confidentiality concerning the personal data it processes. Therefore, it is not appropriate to accept that the amount of the sanction should be reduced considering that the number of affected individuals whose integrity and/or confidentiality of their personal data has been compromised is 973, as the loss of control over one's own personal data occurs from the moment the personal data breach materializes, that is, from the moment there is unauthorized access by a third party to the personal data processed by CCC. In any case, what is relevant to understand the breach of confidentiality is that the information is completely at the free disposal of unauthorized third parties.

This is the loss of confidentiality attributed to you, and it is at this point that the loss of control over one's own personal data by the interested parties has materialized.

In the case at hand, due to the type of data processed and affected by the breaches, which CCC seems to disregard, it poses a high risk, in the event of a breach of confidentiality, of being used fraudulently: identity theft, phishing, financial fraud, etc. Moreover, it should also be taken into account that the risk of loss of confidentiality has already materialized due to unauthorized access, meaning

that there is no longer a “probability” of risk of loss of confidentiality and control of individuals over their personal data, but rather the materialization of this risk, which can in turn imply a high risk for the rights and freedoms of individuals who may suffer identity theft, fraud, or financial losses.

Therefore, it is noted that the breach of confidentiality attributed to CCC is the one that corresponds to it, that is, for failing to comply with the obligation imposed in Article 5.1.f) to process the data in such a way as to ensure adequate security, including protection against unauthorized or unlawful processing, through the application of appropriate technical or organizational measures.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
30/62

CCC states that it does not agree with the aggravating circumstances taken into account when determining the calculation of the sanction. Thus:

o

The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the data processing operation in question, as well as the number of affected individuals and the level of damage and harm they have suffered (Article 83.2 a) of the GDPR):

It understands that the amount of the sanction should be reduced considering that the number of affected individuals whose integrity and/or confidentiality of their personal data has been compromised is 973. Furthermore, it considers that, although a set of data (name and surname, complete postal address, and date of birth) has been affected in these cases, such data is not critical, especially considering that, as stated (Document 2), the ultimate goal pursued by the third party is to commit economic fraud, with the affected personal data being a means to commit such fraud, not an end in itself.

In this regard, it should be noted that such considerations cannot be accepted as mitigating factors or as circumstances that diminish the severity of the facts; rather, the opposite is true, as precisely because of the high number of treatments carried out and the clients affected, CCC is obliged to act with the special diligence that must be required of an entity of these characteristics, which carries out numerous personal data processing operations. Lastly, the considerable number of individuals affected by personal data breaches cannot be overlooked. The investigative actions carried out have confirmed that the number of affected individuals whose integrity and/or confidentiality of their personal data has been compromised is 118,954, given that there was unauthorized access to personal data by a third party, which resulted in the loss of confidentiality and control over numerous personal data and affected all those whose data was disclosed, not just those clients whose data was subsequently impersonated.

It is worth recalling the Judgment of the National Court of 17/10/2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, indicates that "...the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be particularly weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

In the case at hand, the type of data that is processed and that was affected by the breaches, which CCC seems to underestimate, poses a high risk, in the event of a breach of its confidentiality, of being used fraudulently: identity theft, phishing, financial fraud, etc.

o

The intentionality or negligence in the infringement (Article 83.2 b) of the GDPR:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

It is understood that the existence of due diligence would be supported by the successful completion of the audit of ***COMPANY.4 and provides a 2022 report of the evaluation carried out from September to October 2022 regarding the security of the information systems of ***COMPANY.5 (Document 5), (...) (Document 6), as well as by the fact that the second factor of authentication was not – nor is – a market practice in the digital channels of leading Spanish merchants (Document 7). Furthermore, also in relation to the two-factor authentication, it is reiterated that its implementation occurred before October 30, 2023. For the app channel (towards which all attacks were directed except the last one), it was implemented in March 2023.

In this regard, it should be noted that the data controller must implement technical and organizational measures taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons (art. 24.1 GDPR). Therefore, the risk to the rights and freedoms of individuals must be identified and assessed, and measures must be applied considering, among other circumstances, the "context" in which the measures are to be defined and applied, which in this case was that of a succession of personal data breaches suffered by CCC.

The documentation provided does not reflect the new risks to the rights and freedoms of individuals arising from the breaches suffered by Carrefour and, moreover, the existence of these events is what differentiates Carrefour from other contexts in which other digital channels of other leading Spanish merchants may find themselves.

Therefore, the fact that the second factor of authentication was not – nor is – a market practice in the digital channels of leading Spanish merchants cannot be taken into consideration in this case. In terms of data protection, the technical and organizational measures to be adopted by the data controllers and other obligations to be fulfilled as required by the GDPR must be appropriate in relation to the specific risks posed by the specific processing carried out by each controller. Thus, when analyzing the diligence of each party in complying with the regulations, the circumstances of each case must be taken into account, considering the nature, scope, context, and purposes of each processing, and therefore, there are no identical cases.

In this regard, it is worth recalling that it was not until after the fifth breach (specifically on October 30, 2023) that the decision was made to implement 2FA (with OTP key sending) for logins to the Ecommerce digital channel. Having this measure in place beforehand would have likely prevented all attacks occurring in this channel, which demonstrates a lack of diligence on the part of CCC when implementing appropriate technical measures to ensure an adequate level of security relative to the risks to the rights and freedoms of individuals. The implementation of Two-Factor Authentication (2FA) undoubtedly constituted a significant advancement in the protection of data security. However, this advancement came too late, after critical vulnerabilities had manifested and up to 5 personal data breaches had occurred with widespread effects and the same entry vector.

The fact that CCC is a large company that constantly and abundantly handles personal data in its activities, performing processing that involves a...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

The probable high risk to the rights and freedoms of individuals implies a greater diligence requirement in the processing of personal data than what can be demanded from a small company that conducts sporadic or ancillary processing.

Furthermore, CCC understands that the following circumstances should be considered as mitigating factors:

i. Any other measures taken by the data controller to alleviate the damages suffered by the affected individuals (Article 83.2 c) of the GDPR).

It considers that the fact that CCC took measures to alleviate the damages suffered by the affected individuals should be taken into account as a mitigating factor. In this regard: it reset the credentials that had been affected; and in those cases where fraud occurred with the chequesAhorro, CCC reimbursed the amount of the chequeAhorro and issued gift cards for the affected individuals, so that, as it claims, they did not suffer any economic impact resulting from the fraud.

Moreover, it states that these measures were taken spontaneously, before CCC became aware of the information requests and the initiation of the Agency's investigation.

In this regard, it should be noted that the effects of the breach of personal data not only had economic effects, resulting from the fraud in the chequesAhorro, but went much further, as the loss of confidentiality of personal data implied a greater risk to the rights and freedoms of the affected individuals, even as indicated, their credentials were sold on ***APP.1.

ii. The degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement (Article 83.2 f) of the GDPR), as well as how the supervisory authority became aware of the infringement, particularly whether the controller reported the infringement and, if so, to what extent (Article 83.2 h of the GDPR).

CCC considers that this mitigating factor applies to the extent that the Initiation Agreement was issued as a result of the five breaches of personal data security reported by CCC to the Agency. It asserts that it should be valued as a mitigating factor that it was reported, diligently fulfilling this duty. Information was provided with total transparency and therefore it also understands that these mitigating circumstances should apply. Finally, CCC has cooperated favorably with the investigation, responding to all requests made.

In this regard, it should first be noted that notifying the supervisory authorities and informing the affected individuals of the breach of personal data security are obligations imposed on the data controller by the GDPR (Articles 33 and 34 respectively), that is, their observance is mandated by legal imperative, it is a mandate that must be fulfilled, so non-compliance by the controller, in accordance with the requirements of these provisions, may constitute a breach of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/62

Secondly, the requirements of the AEPD are mandatory. Therefore, in this case, the degree of cooperation with the Agency cannot be appreciated, and it is not appropriate to apply the mitigating factor, since the consideration of cooperation with the Agency as a mitigating factor, as the entity intends, is not linked to any of the situations in which a collaboration or cooperation is legally provided for or in response to a requirement due to a legal mandate. Therefore, when the actions are due and required by law, as in the case at hand, their application is not appropriate.

Consequently, the allegations must be dismissed, noting that the arguments presented do not undermine the essential content of the infractions attributed nor do they constitute sufficient justification or exculpation.

ALLEGATION THREE: CCC adopted appropriate security measures.

(i) Regarding the measures, CCC indicates that it did adopt adequate technical and organizational measures to prevent the loss of integrity and confidentiality from occurring again and, in any case, to effectively reduce the likelihood of the materialization of the loss of integrity and confidentiality of its clients' personal data, referring in its written allegations to a list of these measures and asserting that it complies with the requirements of Article 32 of the GDPR.

In response, it should be noted that, from the facts that occurred, the opposite is deduced. CCC, when assessing the risks of variable probability and severity, should have taken into account the risk to the rights and freedoms of natural persons and applied appropriate technical and organizational security measures to ensure an adequate level of security relative to the risk. Security. Only security.

CCC is charged with the infringement of the aforementioned Article 32, regardless of whether a confidentiality breach has occurred or not, because the reprehensible conduct that violates this provision is the lack or inadequacy of security measures; that is, it is infringed and sanctioned

regardless of whether a personal data breach has occurred or not.

From the analysis of the documentation provided by CCC in response to the information request, the following results: “(...).”

Therefore, there was a deficiency in the security measures implemented, as the defective measures were not adequate, regardless of whether a personal data breach had occurred or not, since they allowed consecutive accesses from more than 7,000 different IP addresses from different network providers, without detecting anomalous behaviors. This clearly demonstrates a breach of Article 32 of the GDPR, as it requires appropriate measures to ensure an adequate level of security relative to the risk, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/62

To this end, reference must be made to Recital 83 of the GDPR, which establishes that “In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the risks inherent in the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the costs of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which may in particular cause physical, material, or immaterial damage.” (the emphasis is ours)

On the other hand, Article 32 of the GDPR indicates that the measures implemented must include the ability to ensure the confidentiality, integrity, availability, and permanent resilience of the processing systems and services (letter b of Article 32.1 GDPR). Therefore, it is not enough to have measures to react as quickly as possible when confidentiality has been breached; there must also be adequate prior measures to prevent a breach, such as preventive and detective measures aimed at avoiding any loss of confidentiality, integrity, and availability of personal data.

The technical and organizational security measures that must be applied are those relevant to respond to the existing risk, considering, among other factors, the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the probability and severity risks to the rights and freedoms of the data subjects.

In this regard, Article 32 does not establish specific and static security measures; rather, it is up to the controller to determine the necessary security measures at any given time to ensure the confidentiality, integrity, and availability of personal data. Consequently, the protection of the same data may involve different security measures depending on the specificities of the various data processing operations. The security obligation imposed on the data controller by Article 32 of the GDPR is an obligation of means, without requiring that a result has occurred for its infringement: the loss of confidentiality, integrity, or availability.

As specified by the Supreme Court ruling of 15/02/2022 (cassation appeal 7359/2020), “In obligations of means, the commitment undertaken is to adopt the technical and organizational means, as well as to deploy diligent activity in their implementation and use, aimed at achieving the expected result with means that can reasonably be classified as suitable and sufficient for its achievement; hence they are referred to as 'diligence' or 'behavior' obligations.” (The emphasis is ours).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/62

It is also relevant the CJEU ruling of 14/12/2023, case C-340/21, in which the Court states the following:

“(…) the appropriateness of such technical and organizational measures must be assessed in a graduated manner. On the one hand, it is necessary to identify the risks of violation of personal data security posed by the processing and its possible consequences for the rights and freedoms of individuals. This assessment must be carried out in each specific case, taking into account the likelihood of the identified risks and their severity. Subsequently, it must be verified whether the measures adopted by the data controller are adapted to these risks, considering the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing.” (paragraph 42).

In this case, the measures implemented by CCC did not guarantee an adequate level to the risk, as they did not take into account the identified risks and their severity. CCC was experiencing a series of successive personal data breaches and did not adopt appropriate measures to mitigate the impact in the event of a personal data breach occurring. This is irrespective of whether such a breach ultimately occurred or not.

Indeed, in the audit conducted on the web channel (www.carrefour.es) between February 14, 2023, and March 3, 2023, it is noted in point 5.11 of the report “(…)”. This vulnerability is considered of medium severity.

In the testing phase, CCC stated regarding this vulnerability that it was not accepted, that is, it was not implemented to the extent that the vulnerability – and the consequent recommendations – did not exceed the materiality threshold. However, nothing is mentioned in the report about not exceeding the materiality threshold.

(…)

Moreover, it also did not adopt other recommended short-term security measures in the pentest reports conducted.

In this regard, it is worth highlighting that in the pentest report concerning the audit conducted on the web channel (www.carrefour.es) between February 14, 2023, and March 3, 2023, the following vulnerabilities are also recorded, among others:

(…)

However, according to the pentest report on the Carrefour Web (Carrefour.es), to conduct the tests in the Gray Box mode (…).

At this point, CCC indicates that they were not accepted, that is, they were not implemented to the extent that the vulnerabilities – and the consequent recommendations – did not exceed the materiality threshold. However, the report does not state anything about not exceeding the materiality threshold.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/62

On its part, in the pentest report conducted on the Carrefour APP channel, between February 6, 2023, and February 9, 2023, the following vulnerabilities are recorded, among others:

□

(…).

Regarding these vulnerabilities, Carrefour has stated that the recommendations were not implemented because “they are not applicable, as they are recommendations derived from vulnerabilities that were detected as a result of providing information to the auditor about CCC's system infrastructure and the removal of security measures to facilitate the auditor's work in the pentest in gray box mode.

However, it is noted in point 3 of the pentest report of the APP that “(…)”.

According to the official page of the National Cybersecurity Institute, there are different types of penetration tests (pentesting) depending on the initial information available to the auditor; thus, they can be:

- White box: if they have all the information about the systems, applications, and infrastructure, being

able to simulate that the attack is carried out by someone who knows the company and its systems;

- Gray box: if they have some information, but not all;
- Black box: if they do not have information about our systems; in this case, it simulates what a foreign cybercriminal would do.

Therefore, in the pentesting conducted on the APP, no information was provided to the auditor as it was not a gray box test but a black box test.

Consequently, this allegation by CCC regarding the existence of adequate measures must be rejected.

(ii) CCC indicates that it should be taken into account that certain security measures were deactivated for the audits (gray box).

But as previously indicated, the pentest conducted on the APP was done in Black Box mode and, although it is true that the one conducted on the Web started in Gray Box mode, according to the pentest report on the Carrefour Web (Carrefour.es), to conduct the tests in Gray Box mode (...), this allegation must also be rejected.

(iii) In relation to the critical and high-level vulnerabilities detected in the February 2023 Pentest analyses, a document has been submitted with the report of an expert auditor who certifies and verifies the correction of the critical vulnerability. This report is dated July 19, 2023.

However, regarding the high-level vulnerability (concerning the possible use of outdated software with known vulnerabilities), they claim that they are currently working on remediating it. And other recommendations to address medium-level vulnerabilities recommended have also not been implemented.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/62

for its short-term application, and this despite, as has been indicated, the events suffered by Carrefour. All of this merely reflects a lack of diligence on the part of CCC when applying the appropriate security measures to the risks of the data processing it carries out. It should not be forgotten that both in the application of CCC and on the website, personal data of thousands of customers is processed, which constitutes large-scale processing, thus requiring adequate security measures for that environment, specifically aimed at ensuring that there is no unauthorized access to such personal data.

(iv) It considers that, in this case, if Articles 5.1(f) and 32 of the GDPR were understood to be infringed (which is not the case), we would be facing a single infringement and that the alleged lack of appropriate technical and organizational measures should be understood as encompassed, as a means of perpetration, in the infringement of the principles of integrity and confidentiality.

Well, confidentiality and data security are fundamentally reflected in two independent provisions of the GDPR: in Article 5.1(f) and in Article 32 of the GDPR.

Article 5.1(f) of the GDPR is one of the principles related to processing. The principles related to processing are, on the one hand, the starting point and the closing clause of the legal framework for data protection, constituting true guiding rules of the system with intense expansive force; on the other hand, having a high level of specificity, they are mandatory norms that can be infringed.

Well, Article 5.1(f) of the GDPR incorporates the principle of integrity and confidentiality and determines that personal data shall be processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures. It establishes an obligation of result, not objective.

On the other hand, Article 32 of the GDPR regulates how security in processing should be articulated concerning the specific security measures that must be implemented, in such a way that, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk that includes, among other things, the ability to ensure the confidentiality of the data.

As we can see, Article 32 of the GDPR, although related to Article 5.1(f) of the GDPR, does not circumscribe the principle in its entirety. Article 5.1(f) of the GDPR explicitly requires that confidentiality be guaranteed and requires a loss of confidentiality, availability, or integrity for its attribution. We may find ourselves with

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/62

assumptions in which there are inadequate measures without resulting in a loss of integrity, availability, and confidentiality.

The lack of security measures constitutes an autonomous and independent violation with sufficient substance in itself to be sanctioned without the need for a personal data breach to materialize, and the infringement of Article 32 is not necessary for the existence of an infringement of Article 5.1.f) of the GDPR to be considered.

In the present case:

- The violation of the principles of integrity and confidentiality, both established in the aforementioned Article 5.1.f) of the GDPR, is manifested in the unauthorized access to customer accounts by third parties, in some cases even allowing the modification of personal data and making purchases, which led to the notification of up to five personal data breaches by the data controller CARREFOUR. It is also evidenced in the inadequate management of personal data security breaches.

- The violation of Article 32 of the GDPR is inferred from the statements of the entity under investigation, which acknowledges during the course of the investigation that most of the rules are based on volumetrics due to failures from the same IP, from the same user, or by specific ranges. However, the system allowed the use of more than 7000 different IP addresses from various network providers for access, therefore, the implemented security measures were insufficient. This constitutes a violation of Article 32 of the GDPR. Furthermore, it derives from the lack of implementation of the recommended measures in the pentest reports that would prevent, in the event of an attack, the attacker from accessing personal data.

Subsidiarily, it is considered that the following circumstances should be taken into account:

- o The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered (Article 83.2 a) of the GDPR).

It is understood that there is an inconsistency in the initiation agreement, and it is either considered an aggravating factor that there has been an impact on the Affected Personal Data (in which case it should be limited to the customers effectively affected, not to all users of the website and the application) or, on the contrary, it is considered an aggravating factor that the impact due to the lack of technical and organizational measures affects all users of the website and the application (in which case it cannot be argued that there has been an effective impact on their personal data, since it has only occurred in certain cases).

In any case, it is considered that, despite the fact that in certain cases a set of data (name and surname, complete postal address, and date of birth) has been affected, they are not critical, especially considering that the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

39/62

The ultimate goal pursued by the third party is to commit economic fraud, with the affected personal data being a means to commit such fraud, not an end in itself.

Regarding the duration, it has been observed how the progressive implementation of new measures has reduced the impact (the introduction of the second factor for modifying personal data and for accessing the application, among others), therefore it is understood that this circumstance cannot be

taken into account as an aggravating factor.

As for this aggravating factor, the focus is on the absence of security measures affecting the personal data of Carrefour customers who use the website and the APP. This broad impact amplifies the severity of the infringement, given that there was a risk of loss of confidentiality, availability, and integrity for each customer. Furthermore, regarding the duration of the infringement, the absence of measures extends at least until November 8, 2024, the date on which Carrefour submitted its response to the requested evidence, considering that there are necessary technical or organizational measures that have not been implemented.

o

Intentionality or negligence in the infringement (Article 83.2 b) of the GDPR)

Regarding this circumstance, there is no doubt that the documentation in the proceedings reveals a serious lack of diligence in the management of personal data security.

Additionally, CCC understands that the following circumstances should be considered as mitigating factors:

i. Any other measures taken by the data controller to mitigate the damages suffered by the affected parties (Article 83.2 c) of the GDPR)

CCC adopted technical and organizational measures aimed at reducing the likelihood of the risk materializing. Furthermore, these measures were adopted proactively, that is, prior to becoming aware of the investigations by the Agency that have led to the issuance of the Initiation Agreement.

As previously indicated, CCC would not have adopted measures to prevent unauthorized third parties from exploiting the identified vulnerabilities.

ii. The degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement (Article 83.2 f) of the GDPR), as well as the manner in which the supervisory authority became aware of the infringement, particularly whether the controller notified the infringement and, if so, to what extent (Article 83.2 h of the GDPR).

We refer to what has been stated regarding this circumstance in Allegation Two.

Consequently, the allegations must be dismissed, emphasizing that the arguments presented do not undermine the essential content of the infringements declared to have been committed nor do they constitute sufficient justification or exculpation.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/62

FOURTH ALLEGATION. CCC acknowledges its responsibility regarding the alleged infringement of Article 34 of the GDPR: communication of breaches to affected individuals.

Although CCC initially considered that communication of the breaches to affected individuals was not mandatory, CCC acknowledges its responsibility solely and exclusively for the alleged infringement of Article 34 of the GDPR concerning those individuals whose confidentiality and/or integrity of their personal data was affected, which should result in a 20% reduction of the proposed sanction for this infringement (200,000 euros). Furthermore, if payment is made before the resolution of this procedure, the sanction should be reduced by an additional 20%, resulting in a payment amount of 120,000 euros. The investigated entity acknowledges its responsibility, requesting the reductions of the sanction amount provided for in the regulations.

Article 85.1 of the LPACAP states that “Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.”

Therefore, in the initiation agreement of this sanctioning procedure, it was indicated that “In accordance with the provisions of Article 85 of the LPACAP, you may acknowledge your responsibility within the period granted for the submission of allegations to this initiation agreement; this will entail a 20% reduction of the sanction that may be imposed in this procedure.”

On the other hand, in the same initiation agreement, it was stated that “Likewise, you may, at any time prior to the resolution of this procedure, make a voluntary payment of the proposed sanction, which will

result in a 20% reduction of its amount.” It was indicated that such payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

Additionally, Article 85.3 of the LPACAP states that the effectiveness of such reduction “will be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative route against the sanction.” This aspect is also included in the aforementioned initiation agreement of this sanctioning procedure, which also states that “In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative route against the sanction.”

Therefore, although the investigated entity has acknowledged its responsibility within the period for submitting allegations to the initiation agreement, this has not been accompanied by either the withdrawal or renunciation of filing any action or appeal in the administrative route against the sanction, nor by the payment of it. Thus, in accordance with the provisions of Article 85.2 of the LPACAP, it is informed that you may, at any time prior to the resolution of this procedure, express the withdrawal or explicit renunciation of the administrative route, as well as make the voluntary payment of the proposed sanction, which will entail a 20% reduction of its amount, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/62

IV

Unfulfilled Obligation. Principle of Integrity and Confidentiality.

Article 5.1.f) of the GDPR establishes the following:

“Article 5 Principles relating to processing:

1.

Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures (‘integrity and confidentiality’).”

In relation to this principle, Recital 39 of the aforementioned GDPR states that:

“[...] Personal data must be processed in a manner that ensures adequate security and confidentiality of personal data, including to prevent unauthorized access or use of such data and the equipment used for processing.”

According to the Guidelines on the notification of personal data breach under Regulation 2016/679 of the GT29, a “confidentiality breach” occurs when there is an unauthorized or accidental disclosure of personal data, or access to it; an “integrity breach”: when there is an unauthorized or accidental alteration of personal data; and an “availability breach”: when there is an accidental or unauthorized loss of access to personal data, or destruction of it.

The principle of confidentiality and integrity, within the framework of the GDPR, implies the obligation to ensure that personal data is kept protected and can only be accessed or modified by those who are authorized to process it, for the legitimate purpose provided by the data controller.

In the case at hand, from the investigative actions carried out by this authority, a presumed violation of the aforementioned principle of confidentiality and integrity emerges. This violation is manifested first in the personal data breaches suffered by the entity and reported by the entity under investigation, which are:

(...)

The fact that attackers illegitimately accessed customer accounts likely using the Credential Stuffing attack technique with leaked credentials (email/password pairs), regardless of how they accessed such credentials, and that they were able to modify personal data and make purchases, constitutes a manifestation of the violation of the

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
42/62

principles of integrity and confidentiality, both established in the aforementioned article 5.1.f) of the GDPR.

In this regard, it should not be forgotten, as has been stated in the investigation proceedings and the information transmitted, that the attackers accessed personal data of the clients and modified it, at least in the first reported breach.

The high number of accesses to personal data increases the risk of misuse and fraud and highlights that the technical and organizational measures adopted by the data controller before and after the incidents were not appropriate to ensure the integrity and confidentiality of personal data, especially for protection against unauthorized or unlawful processing.

Article 24 of the GDPR regarding the responsibility of the data controller states in its paragraph 1 that “Taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the data controller shall implement appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is in compliance with this Regulation. Such measures shall be reviewed and updated as necessary. (the underlining is ours)

For its part, Recital 74 of the GDPR declares that “The responsibility of the data controller for any processing of personal data carried out by himself or on his behalf must be established. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of the processing activities with the General Data Protection Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of natural persons.”

And Recital 76 adds that “The probability and severity of the risk to the rights and freedoms of the data subject must be determined with reference to the nature, scope, context, and purposes of the data processing. The risk must be weighed based on an objective assessment through which it is determined whether the data processing operations pose a risk or if the risk is high.”

The WP248 Guidelines of the GT29, on the data protection impact assessment (DPIA) and to determine whether the processing “likely entails a high risk” for the purposes of the GDPR, adopted on April 4, 2017, and last revised and adopted on October 4, 2017, define the concepts of “risk” and “risk management.” A “risk” is a scenario that describes an event and its consequences estimated in terms of severity and probability. On the other hand, “risk management” can be defined as the coordinated activities to direct and control an organization with respect to risk.

As stated in the guide of this AEPD on “Risk management and impact assessment in personal data processing,” “In response to the breach, the controller will have to address, within the risk management cycle, all those measures that are necessary to prevent the incident or breach from occurring.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
43/62

to occur again. This task will involve the review of the controls that were related to the occurrence of the breach, as well as possibly the implementation of new controls that may be necessary.” What this implies, for the purposes here, is the application of those resources, procedures, and controls that may be necessary to ensure compliance with the principle of integrity and confidentiality, which is not evidenced to have been carried out in this case.

In this regard, the aforementioned guideline also states, “As interpreted by the WP218 Declaration, it must be emphasized that addressing the risks that may arise from data processing for the rights and

freedoms of individuals cannot be limited to exclusively applying security measures. Therefore, the management of security risks is one of the activities for managing risks to rights and freedoms and must be subordinated to the latter. Furthermore, from the perspective of the GDPR, mitigation measures must be aimed at reducing the impact and the likelihood that personal data breaches affect the data subject.”

In the present case, 5 personal data breaches occurred, with attackers likely using the Credential Stuffing attack technique, as Carrefour confirmed that there were no brute force attacks and that customer credentials were offered, without Carrefour having demonstrated that it adopted appropriate technical and organizational measures, not only of security, to prevent the loss of integrity and confidentiality from occurring again or to effectively reduce the likelihood of its occurrence, such as verifying the effectiveness of the resources, procedures, and controls implemented, reevaluating the risk, and conducting the necessary reviews within an appropriate timeframe to ensure the confidentiality and integrity of personal data, which is evidenced to have not been done.

Carrefour did not diligently implement two-factor authentication, which would have prevented access to accounts whose credentials may have been affected by the breaches. It should be noted that appropriate technical and organizational measures to ensure an adequate level of security relative to the risk cannot be merely reactive measures, that is, exclusively to immediately address a personal data breach after it has occurred. It is worth remembering that the implementation of Two-Factor Authentication (2FA), while constituting a significant advancement in data security protection, came late and in a reactive manner, after critical vulnerabilities had manifested and up to 5 personal data breaches had occurred with widespread effects.

And it is not only an inadequate management of personal data security breaches that is evident in the late implementation of 2FA, at least in the web channel, but also in other circumstances. Thus, an impact has been noted in the first breach affecting 234 individuals, in the second breach: 35,735 individuals affected, in the third breach: 61,083 individuals affected, in the fourth breach: 10,943 individuals, and in the fifth breach: 10,900 individuals affected. CCC has stated that it reset the affected passwords after the successive breaches and that in the fourth breach the credentials of 1,741 customers were again compromised, who were also affected in the third breach. However, of the 10,943 customers affected in the fourth breach, only the passwords of 9,202 customers were reset, and the passwords of the 1,741 customers were not reset again because they had already been.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

44/62

reset after the third breach, leaving those 1,741 credentials that had been compromised again without a reset.

In this regard, it should not be forgotten, as has been exposed in the investigation proceedings and the information transmitted, that there was an unauthorized third-party access to personal data, which resulted in the loss of confidentiality and control over numerous personal data and affected all those whose data was disclosed, not only those clients whose data was subsequently impersonated.

Regarding the type of personal data that the attacker was able to access in the second personal data breach, once reactive measures were implemented after the first breach detected in January 2023, the investigated entity itself includes a list of personal data that could be accessed, organized by type of data:

- o Name, Surname 1, Surname 2

- o Email Address

- o Contact Phone (masked with asterisks for all digits except the last 3)

- o ID Number (masked with asterisks for all characters except the last 4)

- o Complete postal address: Postal code, Staircase/floor/door, Municipality, Street name, Street number, Province, Type of street, Date of birth.

Furthermore, it is noted in the notification of the third personal data breach, which occurred on April 16,

2023, that the attacker had access to Basic Data (e.g., name, surnames, date of birth), ID Number, Foreign ID Number, Passport and/or any other identifying document, Economic or Financial Data (without payment means), Contact Data, Access or Identification Credentials (username and/or password).

In the notification of the fourth personal data breach, which occurred on June 23, 2023, it is stated that the attacker accessed basic data (e.g., name, surnames, date of birth), Contact Data, Access or Identification Credentials (username and/or password).

In the notification of the fifth personal data breach, which occurred on September 11, 2023, it is stated that the attacker had access to basic data (e.g., name, surnames, date of birth), ID Number, Foreign ID Number, Passport and/or any other identifying document, Contact Data, Access or Identification Credentials (username and/or password).

Consequently, it is considered that the established facts constitute an infringement, attributable to the investigated entity, for violation of Article 5.1.f) of the GDPR.

V

Classification and Qualification of the Infringement

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/62

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% at most of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and will prescribe in three years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VI

Sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 is effective, proportionate, and dissuasive in each individual case.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those contemplated in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level

of damage and harm they have suffered;
b) the intentionality or negligence in the infringement;
c) any measures taken by the data controller or processor to

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
46/62

to mitigate the damages suffered by the interested parties;
d) the degree of responsibility of the controller or the processor, taking into account the technical or organizational measures they have applied pursuant to Articles 25 and 32;
e) any previous infringement committed by the controller or the processor;
f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
g) the categories of personal data affected by the infringement;
h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or the processor notified the infringement and, if so, to what extent;
i) when the measures indicated in Article 58(2) have been previously ordered against the controller or the processor in relation to the same matter, the compliance with such measures;
j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42;
k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 “Sanctions and corrective measures” of the LOPDGDD states:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The link between the infringer's activity and the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.”

According to the transcribed provisions, for the purpose of determining the amount of the sanction for infringement of Article 5.1 f) of the GDPR, it is necessary to graduate the fine taking into account:

As a circumstance for the graduation of the sanction, the following are considered:

Article 83.2 a) GDPR: “the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
47/62

treat, as well as the number of affected parties and the level of damages they have suffered”;
It is worth noting that the violation of the principle of integrity and confidentiality in the present case involves a set of personal data whose nature amplifies the implications of the security breach. This is

evident from the circumstance that certain personal data has been affected, such as name, Last Name 1, Last Name 2, Email Address, complete postal address: Postal Code, Staircase/floor/door, Municipality, Street Name, Street Number, Province, Type of street, Date of birth, and credentials, the exposure of which increases the risk of misuse and fraud, as well as social engineering attacks and cyber scams.

The combination of this type of personal data significantly raises the level of risk to the rights and freedoms of its holders and the implications of the breach of confidentiality. This is due to the fact that such a combination not only increases the amount of information available to a malicious actor but also broadens the spectrum of possible abuses. Since these are not isolated data or individual pieces of information, but rather the exposure of an integrated set of personal data that, when combined, can be used to construct a complete and detailed profile of an individual, this can allow an attacker to carry out fraud and identity theft operations with a higher success rate.

Specifically, online orders were made and payments were processed via QR codes in physical stores, as well as access to usurped accounts through other devices using customer coupons. This level of access increases the risk of misuse and fraud and loss of control over their personal data.

Finally, the considerable number of affected individuals from the breaches cannot be overlooked, given that an impact has been confirmed in the first breach: 234 affected, in the second breach: 35,735 affected, in the third breach: 61,083 affected, in the fourth breach: 10,943 affected, and in the fifth breach: 10,900 affected, which highlights both the scale of the incident and the considerable volume of individuals whose rights and freedoms were compromised. This wide-ranging impact amplifies the severity of the infringement, as each affected customer represents a potential case of fraud, identity theft, or financial loss, exponentially multiplying the negative repercussions of the incident.

Moreover, the infringement is aggravated by the context in which it occurs, where individuals trust the entity for the secure handling of their personal information, with the trust and expectations of the affected parties regarding the processing of their personal data having been eroded.

Article 83.2 b) GDPR: "The intentionality or negligence in the infringement"

The Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the offender does not behave with the required diligence. In assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the entity in question is constant and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

48/62

Given the abundant handling of personal data, it must be emphasized the rigor and exquisite care to comply with the legal provisions in this regard. [Judgment of the National Court of 17/10/2007 (rec. 63/2006)].

From the investigative actions carried out by this authority, a possible insufficiency of technical and organizational measures for the adequate management of personal data security breaches can be inferred, which can be easily deduced from the fact that, despite all breaches having the vector of entry as the illegitimate access to customer accounts, it was not until after the fifth breach (specifically on October 30, 2023) that it was decided to implement 2FA (with OTP key sending) for logins to the Ecommerce digital channel. Having this measure in place beforehand would have most likely prevented all attacks occurring in this channel, which highlights CARREFOUR's lack of diligence in fulfilling the duty to adopt appropriate measures to ensure the confidentiality and integrity of the data. The implementation of Two-Factor Authentication (2FA) undoubtedly constituted a significant advance in the protection of data security. However, this advance came late in a reactive moment, after critical vulnerabilities had manifested and up to 5 personal data breaches had occurred with widespread effects and the same vector of entry.

This circumstance reflects a clear omission by the responsible party in the duty of care towards the protection of its customers' data, which reinforces and amplifies the seriousness of the infringement.

Article 76.2 b) LOPDGDD: "The link between the infringer's activity and the processing of personal data"

The business activity of the investigated entity requires continuous processing of personal data. The company operates in a sector where trust and information security are fundamental, and for this reason, it has the responsibility to ensure with greater rigor the principles of data protection regarding the information it manages by virtue of this activity.

Considering the factors outlined, the assessed amount of the fine is 2,000,000 euros for the infringement of Article 5.1 f) of the GDPR.

VII

Unfulfilled obligation. Security of processing.

Article 32 of the GDPR establishes the following regarding the security of processing:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

49/62

a) pseudonymization and encryption of personal data;

b) the ability to ensure the confidentiality, integrity, availability, and permanent resilience of processing systems and services;

c) the ability to quickly restore the availability and access to personal data in the event of a physical or technical incident;

d) a process of regular verification, evaluation, and assessment of the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to a code of conduct approved pursuant to Article 40 or to a certification mechanism approved pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The data controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data in accordance with the instructions of the controller, unless required to do so by Union or Member State law."

Recital 74 of the GDPR, previously reproduced, states:

"The responsibility of the data controller for any processing of personal data carried out by him or on his behalf must be established. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of natural persons."

It should be noted that the GDPR in the cited provision does not establish a list of measures, nor of the security measures applicable according to the data being processed, but rather states that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk,

indicating that the determination of technical and organizational measures must be made taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, process.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/62

of verification (not audit), assessment, and evaluation of the effectiveness of the measures.

In any case, when evaluating the adequacy of the level of security, particular attention shall be paid to the risks presented by the processing of data, as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same sense, Recital 83 of the GDPR states that:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the risks inherent in the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the costs of their implementation in relation to the risks and the nature of the personal data that must be protected.

When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which are particularly likely to cause physical, material, or immaterial harm.”

The responsibility of CCC is determined by the lack of security measures, as it is responsible for making decisions aimed at effectively implementing appropriate technical and organizational security measures to ensure an adequate level of security relative to the risk to protect the ongoing confidentiality, integrity, availability, and resilience of the processing systems and services.

From the documentation in the procedure, this lack of adequate measures relative to the rights and freedoms of individuals can be inferred, as the system allowed the use of more than 7000 different IP addresses from different network providers for access, which led Carrefour to have to acquire a specific tool to detect anomalous patterns.

The absence of adequate measures is also evident in the reports of the Pentest audit, which documented deficiencies in the controls implemented in the information systems of the investigated entity, compromising the confidentiality and integrity of the information, without the recommendations contained therein being applied.

The Pentest Report on the Carrefour website (Carrefour.es) conducted by ***COMPANY.1 contains the following recommendations and general actions to be taken in the short term:

-(...).

Likewise, the Pentest Report on the Carrefour APP for Android/iOS contains the following general recommendations regarding actions to be taken:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

51/62

“(...)”.

In particular, in the audit conducted on the web channel (www.carrefour.es) between February 14, 2023, and March 3, 2023, (...).

Likewise, the Pentest report regarding the audit conducted on the web channel (www.carrefour.es) includes, among others, the following vulnerabilities:

(...)

On its part, in the Pentest report conducted on the Carrefour APP channel, between February 6, 2023, and February 9, 2023, the following vulnerabilities are noted, among others:

□ (...).

Regarding these three recommendations, Carrefour has stated that they were not implemented because “(...)”.

However, it is noted in point 3 of the Pentest report of the APP that “(...)”.

Therefore, it follows from the above that the technical and organizational security measures implemented by the entity do not constitute an adequate level of security relative to the risk and are not sufficient to prevent unauthorized access to customer data.

Consequently, it is considered that the established facts constitute an infringement attributable to the investigated entity for violation of Article 32 of the GDPR, given that it was aware of the existence of vulnerabilities that could compromise the integrity and confidentiality of personal data and did not adopt technical and organizational measures to prevent it.

VIII

Classification and qualification of the infringement

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount: a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and conduct referred to in paragraphs 4, constitute infringements.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

52/62

5 and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law.”

For the purposes of the statute of limitations, Article 73 “Serious Offenses” of the LOPDGDD states:

“According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious offenses and shall be subject to a two-year statute of limitations for violations that constitute a substantial breach of the articles mentioned therein, particularly the following:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.”

IX

Sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the violations of this Regulation indicated in paragraphs 4, 5, and 6 is effective, proportionate, and dissuasive in each individual case.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage suffered;

- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringements committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, compliance with those measures;
- j) adherence to codes of conduct pursuant to Article 40 or to certification mechanisms approved under Article 42;
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 “Sanctions and Corrective Measures” of the LOPDGDD provides:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

According to the transcribed provisions, for the purpose of determining the amount of the sanction for the infringement of Article 32 of the GDPR, it is necessary to graduate the fine taking into account:

As a circumstance for the graduation of the sanction, the following is taken into account:

Article 83.2 a) GDPR: “the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage suffered”;

Regarding the number of affected data subjects, the absence of security measures affects all customers of the Ecommerce web channel (carrefour.es) and the MiCarrefour application. This broad impact amplifies the severity of the infringement, given that there is a risk of inadequate protection of personal data for each customer.

Furthermore, regarding the duration of the infringement, the absence of measures is understood to last until November 8, 2024, the date on which Carrefour submitted the response to the requested tests, considering that the technical or organizational measures...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

54/62

necessary at least to solve the detected problems had not been applied.

Article 83.2 b) GDPR: "Intentionality or negligence in the infringement"

The Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the offender does not behave with the required diligence. In assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the individual, and there is no doubt that, in the case now examined, when the activity of the entity being claimed involves constant and abundant handling of personal data, it must be emphasized that rigor and exquisite care must be taken to comply with the legal provisions in this regard. [Judgment of the National Court of 17/10/2007 (rec. 63/2006)].

From the actions carried out, there is a clear insufficiency of existing security measures, and a serious lack of diligence in the management of personal data security.

This circumstance reflects a blatant omission in the duty of the responsible party towards the protection of the security of its clients' data, which reinforces and amplifies the seriousness of the infringement and justifies, consequently, the concurrence of this aggravating factor.

Article 76.2 b) LOPDGDD: "The link of the infringer's activity with the processing of personal data"

The business activity of the investigated entity requires continuous processing of personal data.

Furthermore, the company operates in a sector where trust and information security are fundamental, and for this reason, it has the responsibility to ensure with greater rigor the principles of data protection regarding the information it manages by virtue of this activity. The nature of this activity required greater rigor in the adoption of security measures, a requirement that was not materialized in the case at hand.

Considering the factors presented, the assessment that reaches the amount of the fine is 1,000,000 euros for the infringement of Article 32 of the GDPR.

X

Unfulfilled obligation. Communication of a personal data security breach to the affected individual.

Article 34 "Communication of a personal data security breach to the affected individual" of the GDPR establishes:

"1. When it is likely that a personal data security breach results in a high risk to the rights and freedoms of natural persons, the data controller shall communicate it to the affected individual without undue delay.

2. The communication to the affected individual referred to in paragraph 1 of this article shall describe in clear and simple language the nature of the personal data security breach and shall contain at least the information and measures referred to in Article 33, paragraph 3, letters b), c) and d).

3. The communication to the affected individual referred to in paragraph 1 shall not be necessary if any of the following conditions are met:

a) the data controller has implemented appropriate technical and organizational protection measures, and these measures have been applied to the personal data affected by the personal data security breach, in particular those that render the personal data unintelligible to any person not authorized to access it, such as encryption;

b) the data controller has taken further measures that ensure that the high risk to the rights and freedoms of the affected individual referred to in paragraph 1 is no longer likely to materialize;

c) it would involve a disproportionate effort. In this case, a public communication or a similar measure will be opted for, which informs the affected individuals equally effectively.

4. When the data controller has not yet communicated the personal data security breach to the affected individual, the supervisory authority, after considering the likelihood that such a breach entails a high risk, may require it to do so or may decide that one of the conditions mentioned in paragraph 3 is met."

Regarding the first, second, and third personal data breaches, it should be noted that, although Carrefour has not proven that it communicated to the affected individuals in the terms provided in Article 34 of the GDPR, the possible infringement due to its absence must be considered time-barred, by virtue of the provisions of Article 74 of the LOPDGDD.

As for the fourth and fifth personal data breaches, in this case, it has been confirmed that a communication was sent on June 23, 2023, to 9,202 affected individuals and on September 11, 2023, to 10,959 affected individuals, corresponding to the fourth and fifth security breaches, respectively.

From the investigative actions carried out by this authority, the investigated entity itself states that it proceeded to communicate via email, as well as through the push channel in the cases of customers available through this means, and the content of the message sent was as follows:

“Dear customer:

To provide you with a better service, we have reset your password. To obtain a new one, request it at 'Forgot your password?' when accessing the App or the website.

On the website

<https://www.carrefour.es/myaccount>

On the App

Log in and click on 'Forgot your password?'

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

56/62

Best regards,

The Carrefour team”

In relation to the content that this communication must have, Article 34.2 of the GDPR refers to Article 33 of the GDPR. Thus, the content is that collected in Article 33, paragraph 3, letters b), c), and d) of the GDPR, which establishes:

“3. The notification referred to in paragraph 1 shall, at a minimum:

b) communicate the name and contact details of the data protection officer or another point of contact where more information can be obtained;

c) describe the possible consequences of the personal data security breach;

d) describe the measures taken or proposed by the data controller to remedy the security breach, including, where appropriate, the measures taken to mitigate the possible negative effects.”

In this case, the content of the communication sent does not meet the requirements set forth in Article 33.3, paragraphs b), c), and d), and 34.2 of the GDPR, since it refers to the circumstance that the password has been reset, which, for an average consumer reading the notice, may give the impression that there was a potential for a breach to occur, but does not evidence a loss of confidentiality as occurred.

The wording of the communication does not adequately inform about the existence of a security breach, does not provide affected individuals with information about the nature of the security breach suffered, the personal data affected, the consequences of the breach, the measures taken or proposed to remedy the breach, measures to mitigate the possible negative effects, contact details of the DPO or another point of contact for obtaining additional information.

In this regard, it should be noted that Article 34.2 of the GDPR states that the information to the affected individuals shall “describe in clear and simple language the nature of the personal data security breach.”

Consequently, it is considered that the established facts constitute an infringement, attributable to the investigated entity for violation of Article 34 of the GDPR.

XI

Classification and qualification of the infringement

The aforementioned infringement of Article 34 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

57/62

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)" In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 74 "Minor infringements" of the LOPDGDD indicates:

"Minor infringements of a merely formal nature of the articles mentioned in paragraphs 4 and 5 of Article 83 of Regulation (EU) 2016/679 shall be considered minor and shall prescribe after one year, particularly the following:

"(...)"

ñ) The failure to communicate to the affected individual a breach of data security that poses a high risk to the rights and freedoms of the affected individuals, as required by Article 34 of Regulation (EU) 2016/679, unless the provisions of Article 73 s) of this organic law apply.

"(...)"

XII

Sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding to impose an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected individuals and the level of damage suffered;

b) the intentionality or negligence in the infringement;

c) any measures taken by the controller or processor to mitigate the damage suffered by the affected individuals;

d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented in accordance with Articles 25 and 32;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

58/62

e) any prior infringement committed by the data controller or the processor;

f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the potential adverse effects of the infringement;

g) the categories of personal data affected by the infringement;

h) the manner in which the supervisory authority became aware of the infringement, in particular whether the data controller or processor notified the infringement and, if so, to what extent;

i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the data controller or processor in relation to the same matter, compliance with those measures;

j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42;

k) any other aggravating or mitigating factors applicable to the circumstances of the case, such as financial benefits obtained or losses avoided, directly or indirectly, through the infringement."

For its part, Article 76 “Sanctions and corrective measures” of the LOPDGDD states:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the data controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.”

In accordance with the transcribed provisions, for the purpose of determining the amount of the sanction for infringement of Article 34 of the GDPR, it is necessary to graduate the fine taking into account:

As a circumstance for the graduation of the sanction, the following are considered:

Article 83.2 a) GDPR: “the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered”;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

59/62

The facts have affected certain personal data such as name, Last Name 1, Last Name 2, Email Address, complete postal address: Postal Code, Staircase/Floor/Door, Municipality, Street Name, Street Number, Province, Type of street, Date of birth, the exposure of which increases the risk of misuse and fraud.

The number of affected individuals is high, as it has been confirmed that incomplete breach communications were sent, on June 23, 2023, to 9,202 affected individuals and, on September 11, 2023, to 10,959 affected individuals, highlighting both the scale of the incident and the considerable volume of individuals whose rights and freedoms were compromised. This broad impact amplifies the severity of the infringement, as each affected customer represents a potential case of fraud, identity theft, or financial loss, exponentially multiplying the negative repercussions of the incident.

Furthermore, the infringement is aggravated by the context in which it occurs, where individuals trust the entity for the secure handling of their personal information, having seen their trust and expectations regarding the processing of their personal data eroded.

Article 83.2 b) GDPR: “The intentionality or negligence in the infringement” - in complying with the obligations imposed by data protection regulations, Carrefour has acted with gross negligence in providing the affected individuals with all the information required by the aforementioned Article 34 of the GDPR, so that they could quickly take all necessary measures to protect themselves from the consequences of personal data breaches, taking into account, in addition, the considerable volume of affected individuals, which constitutes an aggravating factor.

Article 76.2 b) LOPDGDD: “The link of the infringer's activity with the processing of personal data”

The business activity of the investigated entity requires continuous processing of personal data. The company operates in a sector where trust and information security are fundamental, and for this reason, it has the responsibility to ensure with greater rigor the principles of data protection regarding the information it manages by virtue of that activity.

Considering the factors outlined, the assessment of the amount of the fine is 200,000 euros for the infringement of Article 34 of the GDPR.

XIII

Adoption of measures

The text of the resolution establishes what the infringements committed have been and the facts that have led to the violation of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

In this case, this authority proceeds to require the responsible party, regarding the violation of Article 34, to notify this Agency within one month of the adoption of the following measure: the communication of personal data breaches to the affected individuals whose data has been affected in the terms and conditions provided by Article 34 of the GDPR.

It is warned that failure to comply with the order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, and such conduct may lead to the initiation of further administrative sanctioning procedures.

Therefore, in accordance with the applicable legislation and assessed the criteria for the graduation of the sanctions whose existence has been established, the Presidency of the Spanish Data Protection Agency RESOLVES:

FIRST: TO IMPOSE on CENTROS COMERCIALES CARREFOUR, S.A., with NIF A28425270,

- for the infringement of Article 5.1.f) of the GDPR, classified in accordance with the provisions of Article 83.5 of the GDPR, qualified as very serious for the purposes of prescription, in Article 72.1 a) of the LOPDGDD, a fine of 2,000,000 euros.

- for the infringement of Article 32 of the GDPR, classified in accordance with the provisions of Article 83.4 of the GDPR, qualified as serious for the purposes of prescription, in Article 73 f) of the LOPDGDD, a fine of 1,000,000 euros.

- for the infringement of Article 34 of the GDPR, classified in accordance with the provisions of Article 83.4 of the GDPR, qualified as minor for the purposes of prescription, in Article 74 ñ) of the LOPDGDD, a fine of 200,000 euros.

SECOND: TO ORDER CENTROS COMERCIALES CARREFOUR, S.A., with NIF A28425270, that pursuant to Article 58.2.d) of the GDPR, within 1 month from the date this resolution becomes firm and enforceable, to prove that it has proceeded to comply with the following measure: the communication of personal data breaches to the affected individuals whose data has been affected in the terms and conditions provided by Article 34 of the GDPR.

THIRD: TO NOTIFY this resolution to CENTROS COMERCIALES CARREFOUR, S.A., with NIF A28425270.

FOURTH: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having made use of this faculty.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

61/62

The sanctioned party is hereby warned that they must comply with the imposed sanction once this resolution becomes executive, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No. IBAN: ES00-0000-0000-0000-0000

(BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection, at the banking entity CAIXABANK, S.A.

Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once it is executive, if the date of executiveness falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 76.4 of the LOPDGDD and given that the amount of the imposed sanction exceeds one million euros, the information identifying the offender, the committed infringement, and the amount of the sanction will be published in the Official State Gazette.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Presidency of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-100325

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

62/62

Lorenzo Cotino Hueso

President of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es